

INCIDENT REPORT

Phishing Email Investigation & Account Compromise

Synthetic Cybersecurity Portfolio Project

Organization	Northstar Financial Services
Incident Type	Credential Phishing / Microsoft 365 Account Compromise
Incident Date	September 29, 2026
Severity	High
Status	Contained - Follow-up Investigation Pending

Training Disclaimer: This report documents a synthetic cybersecurity investigation. All organizations, employees, domains, IP addresses, messages, and security events are fictional.

1. Executive Summary

A credential-phishing campaign impersonating Microsoft 365 targeted 12 employees at Northstar Financial Services. The phishing message directed recipients to a fraudulent Microsoft 365-style sign-in page. Two employees clicked the embedded link, and one employee submitted credentials. The affected employee later approved an MFA request, after which an unfamiliar source IP successfully authenticated to the employee's Microsoft 365 account.

During the unauthorized session, mailbox contents were accessed, an external forwarding rule was created, a customer invoice was downloaded, two emails were forwarded externally, and a password-reset link for an internal expense application was opened. Security contained the Microsoft 365 account by disabling access, initiating a password reset, revoking active sessions, and preserving and removing the unauthorized forwarding rule. The incident was assessed as High severity because account compromise and information exposure were confirmed. Follow-up review remains necessary to determine the sensitivity and downstream impact of the exposed information.

2. Incident Classification

Field	Assessment
Classification	Malicious - Credential Phishing / Account Compromise
Severity	High
Status	Contained - Follow-up Investigation Pending
Affected Service	Microsoft 365
Campaign Scope	12 delivered; 2 URL clicks; 1 credential submission; 1 confirmed compromised account

3. Investigation Scope and Evidence

The investigation reviewed the reported phishing message, email headers, embedded URL behavior, campaign delivery scope, URL interaction telemetry, MFA events, Microsoft 365 authentication activity, mailbox activity, and post-compromise actions. The evidence in this portfolio exercise is synthetic.

4. Phishing Email Analysis

- Sender used the lookalike domain micros0ft-support.com, substituting the number 0 for the letter o.
- The message created urgency by claiming the Microsoft 365 password would expire and requiring action within 30 minutes.
- The embedded URL directed the recipient to an external domain with no identified Microsoft affiliation.
- Email authentication results showed SPF fail, DKIM none, and DMARC fail.
- The destination page imitated a Microsoft 365 sign-in page and requested an email address and password.
- The synthetic domain was three days old and had no existing reputation data; lack of reputation was treated as unknown rather than safe.

Analyst classification: Malicious - Credential Phishing.

5. Campaign Scope

Measure	Result
Messages delivered	12
Messages reported as phishing	1
Recipients who clicked the URL	2
Credential submissions detected	1
Confirmed compromised Microsoft 365 accounts	1

The second employee who clicked the URL had no detected credential submission. Their account activity should still be reviewed as a precaution because a click alone does not rule out other interaction or exposure.

6. Incident Timeline

Time	Event
09:12:04	Phishing email observed in Rachel Kim's mailbox.
09:18	Rachel Kim reported the message as phishing.
09:58:41	MFA challenge denied by Employee C.
09:59:13	Second MFA challenge denied.
10:02:52	Third MFA challenge approved.
10:03:01	Successful Microsoft 365 authentication from unfamiliar IP 198.51.100.24.
10:07:16	Unauthorized inbox forwarding rule created.
10:03-10:19	Unauthorized Microsoft 365 session; mailbox review confirmed access and information exposure.

7. Account Compromise Analysis

The credential submission was followed by repeated MFA challenges. The employee denied the first two requests but approved the third, believing Microsoft required confirmation. Nine seconds later, a successful authentication occurred from an IP address not recognized in the employee's normal account history. This sequence is consistent with MFA fatigue (also called MFA bombing or MFA push spam) following credential theft.

The approved MFA request should not be treated as evidence that the subsequent login was legitimate. The unfamiliar source, timing, and post-login mailbox changes support treating the session as unauthorized.

8. Confirmed Impact

- Unauthorized Microsoft 365 session from approximately 10:03 AM to 10:19 AM.
- Seven emails opened during the unauthorized session.
- Internal employee communications accessed.
- One customer invoice PDF accessed and downloaded.
- Two emails forwarded to an external address before the forwarding rule was removed.
- Password-reset email for an internal expense application accessed, and its reset link opened.

No successful login to the expense application from an unfamiliar source was identified. No additional compromised Microsoft 365 accounts were identified at the time of analysis. The evidence therefore confirms mailbox information exposure but does not establish successful compromise of the expense application.

9. Indicators and Authentication Evidence

Indicator	Value
Sender / Return-Path	security-alert@microsoft-support.com
Sending host	mail.microsoft-support.com
Synthetic sending IP	203.0.113.77
Phishing URL	https://microsoft-accountverify.example/login
Unauthorized authentication IP	198.51.100.24
Email authentication	SPF fail; DKIM none; DMARC fail

10. MITRE ATT&CK Mapping

T1566.002 - Spearphishing Link

The phishing email contained a link to a fraudulent sign-in page designed to collect credentials.

T1621 - Multi-Factor Authentication Request Generation

Multiple MFA requests were generated after credential submission; two were denied before a third was approved.

T1114.003 - Email Forwarding Rule

An unauthorized inbox rule was created to forward incoming messages to an external address.

11. Containment and Response

- Disabled or locked the compromised Microsoft 365 account.
- Initiated a password reset for the compromised account.
- Revoked active sessions and authentication tokens.
- Reviewed MFA activity and secured the affected user's authentication methods.
- Preserved the unauthorized forwarding rule as evidence before removing it.
- Reviewed mailbox activity to determine post-compromise actions and information exposure.
- Quarantined or removed the phishing message from affected mailboxes and blocked relevant indicators where appropriate.
- Reviewed the second URL-click recipient for signs of compromise.
- Invalidated the expense-application password-reset path and secured the associated account as a precaution.
- Escalated information-exposure findings to appropriate security, management, privacy, legal/compliance, and data owners according to incident-response procedures.

12. Recommendations

- Continue reviewing the seven accessed messages and two externally forwarded emails to determine information sensitivity and notification requirements.
- Verify that no additional sessions, tokens, inbox rules, delegated access, or persistence mechanisms remain on the affected account.

- Review Employee B's account and endpoint telemetry because the phishing URL was clicked even though credential submission was not detected.
- Strengthen phishing-resistant authentication or MFA configurations that reduce susceptibility to repeated push-request abuse where feasible.
- Provide targeted awareness training on phishing reporting, lookalike domains, credential-harvesting pages, and unexpected MFA prompts.
- Use email and web controls to block confirmed malicious indicators and remove remaining copies of the phishing message.

13. Analyst Conclusion

A credential-phishing campaign impersonating Microsoft 365 targeted 12 employees and directed recipients to a fraudulent credential-harvesting page. Two employees clicked the phishing link, and one employee submitted credentials and subsequently approved an MFA request, after which an unfamiliar source IP successfully authenticated to the employee's Microsoft 365 account.

During the unauthorized session, the attacker accessed mailbox contents, created an external forwarding rule, downloaded a customer invoice, forwarded two emails externally, and opened a password-reset link associated with an internal expense application. Security contained the compromised account by disabling access, initiating a password reset, revoking active sessions, and preserving and removing the unauthorized forwarding rule.

The incident remains High severity. Investigation should continue to determine the sensitivity and downstream impact of the exposed information and to verify that no additional access occurred.

14. Skills Demonstrated

Phishing analysis; email-header analysis; URL analysis; credential-phishing classification; authentication-log analysis; MFA-fatigue recognition; incident scoping; Microsoft 365 account-compromise analysis; mailbox investigation; MITRE ATT&CK mapping; incident severity assessment; containment planning; evidence-based reporting; and executive/technical communication.